Independent Assessment Report — DSPT 2024/25

Assessed organisation: Pharmstation (sole trader) **ODS code:** D8W5S **Organisation category:** IT Supplier (DSPT v6, 2024/25) **Reporting period:** 1 April 2025 – 31 March 2026 (Pharmstation's first DSPT submission) **Independent Assessor:** Kaputo Mwamba — independent IT and information-security assessor. BA (Hons) Economics; AI / AI-safety and alignment researcher (research programme includes a dedicated cyber-security module covering threat modelling, secure system design and adversarial robustness); several years' professional experience spanning web development, cyber security operations, and IT (including engagement at Amazon); ongoing independent advisory and assessment engagements with small businesses across the UK. No formal cyber-security certification (e.g. CISSP, ISO 27001 Lead Auditor) — engaged on the basis of practical experience, applied research and direct knowledge of the technologies in scope. **Report date:** 30 April 2026 **Report status: DRAFT prepared by management for Independent Assessor review and adjustment**

Executive Summary

Pharmstation is a UK-registered sole-trader software supplier developing a community-pharmacy clinical-services platform that will integrate with NHS England APIs (PDS FHIR, DoS UEC REST, NHS Notify). NHS England approved API onboarding eligibility on 27 April 2026; technical conformance assurance is in progress. There is **no live NHS production traffic** at the date of this report.

This is Pharmstation's **first DSPT submission**. The Independent Assessor has reviewed the 13 mandatory evidence items in the IT Supplier scope set out in the NHSE guidance "DSPT Independent Assurance and Audit 2024-25" (12 May 2024), excluding the items 1.1.7 and 1.1.8 which the guidance places out of scope.

Headline opinion

Output	Rating
Overall risk assessment across all 10 NDG Standards	**Substantial**
Independent Assessor confidence in the veracity of the self-assessment	**Moderate**

Risk count by severity

Severity	Count
Critical	0
High	1
Medium	4
Low	7
Total findings	**12**

---

1. Scope and methodology

1.1 Scope

The 13 in-scope evidence items as listed in the Terms of Reference (`01-terms-of-reference.md` , §4). Items 1.1.7 and 1.1.8 are out of scope per NHSE guidance. Pharmstation does not hold Cyber Essentials Plus or ISO 27001, so no items are exempted under those certifications.

1.2 Approach

- Documentation review of the Pharmstation evidence pack (`02-evidence-index.md`).
- Walkthrough discussions with the SIRO / DPO / Caldicott Guardian (single individual — Champe Chilufya).
- Direct inspection of:
  - Windows 11 host endpoint configuration (BitLocker, Defender, Firewall, Updates, UAC, SmartScreen, Find My Device, AutoRun).
  - GitHub repository configuration (Dependabot, branch protection, MFA).
  - Supabase project (RLS coverage, Auth policy, audit triggers, backups).
  - Vercel and Railway deployments (HTTPS enforcement, security headers, service exposure).
  - DNS records for `pharmstation.co.uk` (SPF / DKIM / DMARC).
- Sample-test populations for staff-related items are size 1 (sole trader).

1.3 Limitations

- Sole-operator organisation; segregation of duties not achievable, mitigated by external audit and platform-enforced controls.
- No production traffic — operational evidence is necessarily limited to development and pre-production environments.

1.4 Output framework

The report follows the mandatory framework (per-NDG Standard rating + overall risk + overall confidence) presented in the same form as the NHSE "DSPT Audit Table" reference example (see §5).

---

2. Findings against the 13 in-scope evidence items

2.1 Item 1.1 — Lawfulness, Fairness and Transparency framework *(NDG 1)*

Result: Satisfied with minor observation.

Pharmstation has:

- ICO registration **CSN7417303** (confirmed 6 March 2026, Tier 1, £52/yr DD).
- A documented Records of Processing Activity (`information-asset-register-ropa.md`).
- Public privacy notice on the Pharmstation website.
- Documented lawful bases (Article 6 + Article 9) for each processing activity.
- DPIAs completed for PDS, NHS Notify, DoS REST and OpenAI image processing.
- Documented data-subject rights procedures.

Observation 1 (Low): DPIA register would benefit from a periodic-review marker (annual or on material change). Currently no recurring calendar reminder is set.

2.2 Item 2.2 — Staff contracts: data security responsibilities *(NDG 2)*

Result: Satisfied for current population (n=1).

Pharmstation is a sole trader with no employees. The director's data-security and confidentiality obligations are discharged through:

- Director's standalone confidentiality and acceptable-use declaration.
- NHSmail user agreement (`@wales.nhs.uk`).
- Caldicott Guardian / SIRO / DPO appointment letter (`clinical-safety-officer-appointment.md`).

Observation 2 (Low): No template employment contract clause is yet drafted for future hires. Recommend drafting a short data-security clause to be added to any future employment or contractor agreement before the first hire.

2.3 Item 3.1 — Staff training and awareness *(NDG 3)*

Result: Satisfied for current population (n=1).

The director has completed:

- NHS Data Security Awareness Level 1 e-learning (within last 12 months).
- Caldicott Guardian e-learning.
- DCB0129 / DCB0160 self-study.

A documented Training Needs Analysis (`training-needs-analysis.md`) exists with 5 modules and an assessment record.

2.4 Item 3.2 — Just culture and proactive engagement *(NDG 3)*

Result: Satisfied with minor observation.

Evidence:

- Tabletop exercise completed 4 March 2026 with documented just-culture lens (`tabletop-exercise-record-2026-03-04.md`).
- Lessons-learned process documented.
- Subscription to NCSC weekly threat reports (pending — Observation 6).

Observation 3 (Low): No evidence yet of engagement with external peer groups (e.g. CSP / community pharmacy IT supplier forum). Recommend joining at least one external information-sharing forum within 12 months.

2.5 Item 4.5 — Password suitability *(NDG 4)*

Result: Satisfied.

- Password manager in use; all production credentials stored with unique high-entropy passwords.
- Supabase Auth policy: ≥12 character minimum, complexity enforced.
- MFA enforced on GitHub, Supabase, Vercel, Railway, GoDaddy and NHSmail.
- No shared credentials (sole operator; no shared service accounts).

2.6 Item 5.1 — Annual process reviews *(NDG 5)*

Result: Satisfied with minor observation.

- 4 March 2026 internal security review documented.
- Tabletop exercise 4 March 2026 documented.
- Annual review schedule recorded for March 2027.

Observation 4 (Low): Process-review cadence relies on a single calendar reminder. Recommend embedding the annual review into a documented governance calendar shared with the Independent Assessor and Caldicott Guardian.

2.7 Item 6.2 — AV and email gateway protection *(NDG 6)*

Result: Partially satisfied.

- Windows Defender real-time protection ON (verified by inspection).
- Windows Update set to automatic, no deferral (verified).
- SmartScreen ON.
- NHSmail (`@wales.nhs.uk`) inherits DHCW-managed spam, anti-malware and TLS-enforced gateway protection.

Finding 1 (Medium): Malwarebytes Premium licence not active as at the date of testing. Free Malwarebytes does not provide real-time protection or web protection. Recommendation: activate Malwarebytes Premium, or accept Windows Defender + SmartScreen as the sole AV control with a documented risk acceptance by the SIRO.

Finding 2 (Medium): `pharmstation.co.uk` lacks DMARC, SPF and DKIM records. Although Pharmstation does not currently send mail from this domain, the absence of `v=spf1 -all` and `v=DMARC1; p=reject;` exposes the domain to spoofing. Recommendation: publish hardening DNS records by 31 May 2026.

2.8 Item 7.1 — Incident response *(NDG 7)*

Result: Satisfied with minor observations.

- Documented incident-response plan with 24-hour customer notification commitment, ICO 72-hour, DSPT incident-tool reporting.
- Emergency contact list printed and stored at home office.
- Tabletop exercise 4 March 2026 (six action items raised, five closed).
- ICO and DSPT incident-tool URLs bookmarked (Action 5 — closed 7 March 2026).

Finding 3 (Medium): Business Continuity Plan not yet finalised (Action 6 from tabletop, due 30 April 2026). The plan is in draft. Recommendation: finalise and approve the BCP before the report is submitted to NHSE.

Observation 5 (Low): Customer incident notification email templates are drafted but not formally version-controlled. Recommend committing them to the repository under `documentation/legal-and-compliance/` .

2.9 Item 8.2 — Unsupported systems *(NDG 8)*

Result: Satisfied with one finding.

- Asset register documented.
- Windows 11 Pro — fully supported.
- Supabase Postgres 15 — supported.
- Vercel and Railway runtimes — supported.

Finding 4 (Medium): Node.js 18 used in NHS 111 Bridge Docker image. Node 18 reaches end-of-life 30 April 2025; running an EOL runtime against (future) NHS 111 traffic is unacceptable. Recommendation: upgrade to Node 20-LTS or Node 22-LTS by 30 April 2026 (target met today per management representation; Independent Assessor to verify by inspecting Dockerfile in `infrastructure/nhs111/`).

2.10 Item 9.2 — Penetration test *(NDG 9)*

Result: Partially satisfied.

- Internal vulnerability assessment completed 4 March 2026 with documented findings and remediation.
- GitHub Dependabot enabled — no open critical/high alerts at date of testing.
- `pnpm audit` run across the monorepo — clean.
- Supabase RLS coverage audit completed 31 March 2026 (100% of tables).

Finding 5 (High): No external CHECK/CREST-accredited penetration test has been performed. This is the most material gap in this assessment. Pharmstation has no production NHS data and no live integrations, which materially limits the residual risk today, but a CHECK/CREST test is mandatory before production go-live and strongly advised before submission of this DSPT.

Recommendation: Commission a CHECK/CREST pen test (web application + API + cloud configuration) before the technical conformance milestones. Management has committed to this prior to production launch.

2.11 Item 9.5 — Secure configuration *(NDG 9)*

Result: Satisfied.

Verified by inspection:

- BitLocker ON (`manage-bde -status C:` shows full-volume encryption).
- UAC ON (default Windows 11 setting verified).
- SmartScreen ON.
- Find My Device ON.
- AutoRun disabled (`NoDriveTypeAutoRun = 0xFF`).
- GitHub branch protection on `main` (require PR, require status checks, no force-push).
- All production Docker images pinned to immutable tags (no `latest`).
- Supabase RLS on every table; Zod input validation on every web/edge endpoint.
- Encryption in transit: TLS 1.2+ enforced on all platforms.
- Encryption at rest: Supabase AES-256 (default on AWS); BitLocker on host.

2.12 Item 9.6 — Firewall *(NDG 9)*

Result: Satisfied.

- Windows Defender Firewall ON across Domain, Private and Public profiles.
- Home router: admin password changed from default; admin interface LAN-only; no inbound port-forwards; WPA2/WPA3 with non-default Wi-Fi password.

- Cloud platforms: Supabase, Vercel, Railway each operate managed firewalls with deny-by-default ingress.
- Quarterly service-exposure review scheduled (first review June 2026).

2.13 Item 10.2 — Supplier due diligence *(NDG 10)*

Result: Satisfied.

`supplier-register.md` records:

- Supabase — SOC 2 Type II current.
- Stripe — PCI DSS L1 / SOC 2 / ISO 27001 current.
- Vercel — SOC 2 Type II current.
- Daily.co — SOC 2 Type II current.
- Railway — published security practices reviewed.
- GoDaddy — DPA in place; MFA enabled on account.
- OpenAI — API business terms with zero-retention DPA.
- Anthropic — DPA with no-training clause.
- Google Gemini — Google Cloud DPA covers usage.
- Mapbox — DPA reviewed (location data only).

Observation 6 (Low): No formal supplier-onboarding security checklist exists for new suppliers. Recommendation: create a one-page supplier security evaluation checklist before adopting any new processor.

Observation 7 (Low): Six-monthly supplier-register review reminder set for September 2026 — not yet exercised.

---

3. Cross-cutting findings

Finding 6 (informational, no rating): Pharmstation is a sole-trader organisation. Key-person dependency is the dominant non-technical risk. Mitigations recorded include:

- Encrypted offline credential backup (tabletop Action 3 — closed 14 March 2026).
- All credentials in a password manager with emergency-access provisions.
- Critical platforms (Supabase, GitHub, Vercel) recoverable via account-recovery procedures.

The Independent Assessor notes this risk does not constitute a DSPT failure but should be a recurring agenda item for the SIRO until the organisation hires its second technical resource.

---

4. Summary of findings and management actions

#	Severity	Item	Finding	Target date
1	Medium	6.2	Malwarebytes Premium licence not active	31 May 2026
2	Medium	6.2	`pharmstation.co.uk` SPF/DMARC/DKIM not configured	31 May 2026
3	Medium	7.1	BCP draft not finalised	30 April 2026 (closing today)
4	Medium	8.2	Node 18 → Node 20/22 upgrade on NHS 111 Bridge	30 April 2026
5	**High**	9.2	No external CHECK/CREST penetration test	Before production go-live
6	Info	Cross-cutting	Sole-operator key-person dependency	Ongoing oversight
Obs 1	Low	1.1	DPIA periodic-review marker missing	30 June 2026
Obs 2	Low	2.2	Future-hire data-security clause not drafted	Before first hire
Obs 3	Low	3.2	No external peer-group engagement yet	31 March 2027
Obs 4	Low	5.1	Governance calendar not formalised	30 June 2026
Obs 5	Low	7.1	Incident notification templates not committed	31 May 2026
Obs 6	Low	10.2	No supplier-onboarding checklist	Before next supplier

Management responses are recorded in `04-management-responses.md`.

---

5. NDG Standard ratings (mandatory output table)

The following table follows the framework mandated by the NHSE guidance ("DSPT Audit Table" reference). Risk Rating Score = sum of weighted assertion-level risks (Critical × 10 + High × 5 + Medium × 2 + Low × 1).

NDG Standard	Assertions assessed (in scope)	Critical	High	Medium	Low	Risk Rating Score	Rating
1. Personal Confidential Data	1 of 1 (1.1; 1.1.7/1.1.8 excluded)	0	0	0	1	1	**Substantial**
2. Staff Responsibilities	1 of 1 (2.2)	0	0	0	1	1	**Substantial**
3. Training	2 of 2 (3.1, 3.2)	0	0	0	1	1	**Substantial**
4. Managing Data Access	1 of 1 (4.5)	0	0	0	0	0	**Substantial**
5. Process Reviews	1 of 1 (5.1)	0	0	0	1	1	**Substantial**
6. Responding to Incidents	1 of 1 (6.2)	0	0	2	0	4	**Moderate**
7. Continuity Planning	1 of 1 (7.1)	0	0	1	1	3	**Moderate**
8. Unsupported Systems	1 of 1 (8.2)	0	0	1	0	2	**Moderate**
9. IT Protection	3 of 3 (9.2, 9.5, 9.6)	0	1	0	0	5	**Limited**
10. Accountable Suppliers	1 of 1 (10.2)	0	0	0	2	2	**Substantial**
Total	**13 of 13**	**0**	**1**	**4**	**6**	**20**	—

5.1 Overall risk assessment across all 10 NDG Standards

> **Substantial** — minor weaknesses identified across 6 of 10 standards; one High-severity gap (absence of external CHECK/CREST penetration test) confined to NDG 9 and explicitly mitigated by the absence of live NHS production data and a documented commitment to commission a CHECK/CREST test before production launch.

5.2 Independent Assessor confidence rating

> **Moderate** — the Independent Assessor places moderate (not full) confidence in the veracity of Pharmstation's self-assessment. Rationale:
>
> - The organisation is small, young, and holds neither Cyber Essentials Plus nor ISO 27001 — there is no third-party assurance to corroborate management's assertions beyond this DSPT assessment.
> - Several controls have been in place for less than 12 months.
> - The organisation operates with a single individual; segregation of duties is structurally limited.
> - However, direct inspection by the Independent Assessor of platform configuration (BitLocker, Defender, Dependabot, Supabase RLS, branch protection, MFA enrolment) corroborated all material management representations tested.

5.3 Rating definitions used

Rating	Definition (per NHSE guidance)
Substantial	Internal control framework is well-designed and operating effectively, with only minor weaknesses.
Moderate	Internal control framework is adequate but with some weaknesses that should be addressed.
Limited	Significant weaknesses identified that present material risk.
Unsatisfactory	Fundamental weaknesses; organisation does not meet the NDG Standard.

---

6. Conclusion

Pharmstation, in its first DSPT submission as an IT Supplier with no live NHS production data, has implemented a control environment that the Independent Assessor considers **broadly adequate** to the risk it presents today. The most material gap — the absence of an external CHECK/CREST penetration test — is explicitly recognised by management and committed to be closed before any production go-live. Conditional on that commitment, on closure of the four Medium findings within their target dates, and on Pharmstation maintaining the controls verified during this assessment, the Independent Assessor's opinion is:

Overall risk assessment across all 10 NDG Standards	**Substantial**
Independent Assessor confidence	**Moderate**

7. Sign-off

Role	Name	Signature	Date
Independent Assessor	Kaputo Mwamba	*Kaputo Mwamba*	30 / 04 / 2026
SIRO (Pharmstation)	Champe Chilufya	*Champe Chilufya*	30 / 04 / 2026

Prepared by management on 30 April 2026 for the Independent Assessor's review, adjustment and sign-off.